

Informe de auditoria - trailofbits/semgrep-rules

Total de reglas auditadas: **120** (definidas en 118 ficheros .yaml; 2 ficheros contienen 2 reglas cada uno)

- APROBAR: 112 (incluye 4 con correccion pendiente antes de copiar, ver notas)
- REVISAR MANUALMENTE: 0
- RECHAZAR: 8

Nota sobre generic/wget-unencrypted-url.yaml: decision tomada con el usuario el 2026-08-04. Se aprueba, pero al copiarla en la Fase 2 a `rules/third-party/trailofbits/generic/` se le deben anadir las mismas 5 exclusiones `pattern-not-inside` que ya tiene su regla hermana `curl-unencrypted-url.yaml` (localhost, 127.0.0.1, 169.254.169.254, `[fd00:ec2::254]`, `metadata.google.internal`), ya que carece de ellas y eso produce falsos positivos en trafico local/metadata de nube. No se copia verbatim del upstream.

Metodologia: se clono trailofbits/semgrep-rules, se ejecuto `semgrep --test` sobre las 120 reglas (en WSL, por un bug de Windows con el fichero de settings de semgrep en ejecucion paralela), se extrajo metadata YAML de cada regla, y se verifico el estado HTTP de las 132 URLs unicas en `metadata.references`.

Fichero	ID	Lenguaje	Patron (amplitud)	Tests (semgrep - --test)	Severity/Confidence coherente	Sospechoso
generic/amqp-unencrypted-transport.yaml	amqp-unencrypted-transport	generic	Acotado, sin indicios de sobre-generalizacion	Si, pasa <code>semgrep --test</code>	Si (WARNING/HIGH, CWE coherente con el mensaje)	Ninguna detecta
generic/container-privileged.yaml	container-privileged	generic	Acotado, sin indicios de sobre-generalizacion	Si, pasa <code>semgrep --test</code>	Si (WARNING/MEDIUM, CWE coherente con el mensaje)	Ninguna detecta
generic/container-user-root.yaml	container-user-root	generic	Acotado, sin indicios de sobre-generalizacion	Si, pasa <code>semgrep --test</code>	Si (WARNING/MEDIUM, CWE coherente con el mensaje)	Ninguna detecta
generic/curl-insecure.yaml	curl-insecure	generic	Acotado, sin indicios de sobre-generalizacion	Si, pasa <code>semgrep --test</code>	Si (WARNING/MEDIUM, CWE coherente con el mensaje)	Ninguna detecta
generic/curl-unencrypted-url.yaml	curl-unencrypted-url	generic	Acotado, sin indicios de sobre-generalizacion	Si, pasa <code>semgrep --test</code>	Si (WARNING/MEDIUM, CWE coherente con el mensaje)	Ninguna detecta
generic/gpg-insecure-flags.yaml	gpg-insecure-flags	generic	Acotado, sin indicios de sobre-generalizacion	Si, pasa <code>semgrep --test</code>	Si (WARNING/MEDIUM, CWE coherente con el mensaje)	Ninguna detecta
generic/installer-allow-untrusted.yaml	installer-allow-untrusted	generic	Acotado, sin indicios de sobre-generalizacion	Si, pasa <code>semgrep --test</code>	Si (WARNING/HIGH, CWE coherente con el mensaje)	Ninguna detecta

Fichero	ID	Lenguaje	Patron (amplitud)	Tests (semgrep - -test)	Severity/Confidence coherente	Sospechoso
generic/mongodb-insecure-transport.yaml	mongodb-insecure-transport	regex	Correcto en diseno (excluye tls=true/ssl=true), pero la exclusion por regex falla en un caso real	NO: <code>semgrep --test</code> falla (1/120). Reporta un falso positivo en la linea 37 de su propio fixture (<code>mongodb://...?ssl=true</code> embebido en un bloque <code>echo '...'</code> multilinea), marcada como <code>#ok</code> en el test pero detectada igualmente.	Si (WARNING/HIGH razonable para CWE-295)	El propio test da patron <code>pattern-r</code> cuando el string de un <code>echo</code> .
generic/mysql-insecure-sslmode.yaml	mysql-insecure-sslmode	regex	Acotado, sin indicios de sobre-generalizacion	Si, pasa <code>semgrep --test</code>	Si (WARNING/MEDIUM, CWE coherente con el mensaje)	Ninguna detecta
generic/node-disable-certificate-validation.yaml	node-disable-certificate-validation	generic	Acotado, sin indicios de sobre-generalizacion	Si, pasa <code>semgrep --test</code>	Si (WARNING/HIGH, CWE coherente con el mensaje)	Ninguna detecta
generic/openssl-insecure-flags.yaml	openssl-insecure-flags	generic	Acotado, sin indicios de sobre-generalizacion	Si, pasa <code>semgrep --test</code>	Si (WARNING/MEDIUM, CWE coherente con el mensaje)	Ninguna detecta
generic/postgres-insecure-sslmode.yaml	postgres-insecure-sslmode	regex	Acotado, sin indicios de sobre-generalizacion	Si, pasa <code>semgrep --test</code>	Si (WARNING/HIGH, CWE coherente con el mensaje)	Ninguna detecta
generic/redis-unencrypted-transport.yaml	redis-unencrypted-transport	generic	Acotado, sin indicios de sobre-generalizacion	Si, pasa <code>semgrep --test</code>	Si (WARNING/HIGH, CWE coherente con el mensaje)	Ninguna detecta
generic/ssh-disable-host-key-checking.yaml	ssh-disable-host-key-checking	generic	Acotado, sin indicios de sobre-generalizacion	Si, pasa <code>semgrep --test</code>	Si (WARNING/MEDIUM, CWE coherente con el mensaje)	Ninguna detecta
generic/tar-insecure-flags.yaml	tar-insecure-flags	generic	Acotado, sin indicios de sobre-generalizacion	Si, pasa <code>semgrep --test</code>	Si (WARNING/MEDIUM, CWE coherente con el mensaje)	Ninguna detecta

Fichero	ID	Lenguaje	Patron (amplitud)	Tests (semgrep - -test)	Severity/Confidence coherente	Sospechoso
generic/wget-no-check-certificate.yaml	wget-no-check-certificate	generic	Acotado, sin indicios de sobre-generalizacion	Si, pasa semgrep --test	Si (WARNING/MEDIUM, CWE coherente con el mensaje)	Ninguna detecta
generic/wget-unencrypted-url.yaml	wget-unencrypted-url	generic	Mas amplio que su regla hermana: no excluye localhost/127.0.0.1/IP de metadata de nube como si hace curl-unencrypted-url.yaml para el mismo escenario	Si pasa semgrep --test	Si	Inconsistencia de url.yaml, que si t localhost/169.25
go/eth-rpc-tracetransaction.yaml	eth-rpc-tracetransaction	go	Demasiado amplio: 12 de las 17 alternativas son regex .*keyword.* sin anclar, que matchean el nombre del metodo JSON-RPC en cualquier string/comentario, no solo en una llamada real	Si pasa semgrep --test	Si, coherente (confidence LOW ya reconoce el ruido esperado)	Ninguna exclusiv etiqueto confide patron
go/eth-txreceipt-status.yaml	eth-txreceipt-status	go	Acotado, sin indicios de sobre-generalizacion	Si, pasa semgrep --test	Si (WARNING/LOW, CWE coherente con el mensaje)	Ninguna detecta
go/hanging-goroutine.yaml	hanging-goroutine	go	Acotado, sin indicios de sobre-generalizacion	Si, pasa semgrep --test	Si (ERROR/MEDIUM, CWE coherente con el mensaje)	Ninguna detecta
go/invalid-usage-of-modified-variable.yaml	invalid-usage-of-modified-variable	go	Acotado, sin indicios de sobre-generalizacion	Si, pasa semgrep --test	Si (WARNING/HIGH, CWE coherente con el mensaje)	Ninguna detecta
go/iterate-over-empty-map.yaml	iterate-over-empty-map	go	Acotado, sin indicios de sobre-generalizacion	Si, pasa semgrep --test	Si (WARNING/MEDIUM, CWE coherente con el mensaje)	Ninguna detecta
go/missing-runlock-on-rwmutex.yaml	missing-runlock-on-rwmutex	go	Acotado, sin indicios de sobre-generalizacion	Si, pasa semgrep --test	Si (ERROR/MEDIUM, CWE coherente con el mensaje)	Ninguna detecta

Fichero	ID	Lenguaje	Patron (amplitud)	Tests (semgrep - --test)	Severity/Confidence coherente	Sospechoso
go/missing-unlock-before-return.yaml	missing-unlock-before-return	go	Acotado, sin indicios de sobre-generalizacion	Si, pasa semgrep --test	Si (ERROR/MEDIUM, CWE coherente con el mensaje)	Ninguna detecta
go/nil-check-after-call.yaml	nil-check-after-call	go	Acotado, sin indicios de sobre-generalizacion	Si, pasa semgrep --test	Si (WARNING/MEDIUM, CWE coherente con el mensaje)	Ninguna detecta
go/racy-append-to-slice.yaml	racy-append-to-slice	go	Acotado, sin indicios de sobre-generalizacion	Si, pasa semgrep --test	Si (ERROR/MEDIUM, CWE coherente con el mensaje)	Ninguna detecta
go/racy-write-to-map.yaml	racy-write-to-map	go	Acotado, sin indicios de sobre-generalizacion	Si, pasa semgrep --test	Si (ERROR/MEDIUM, CWE coherente con el mensaje)	Ninguna detecta
go/servercodec-readrequestbody-unhandled-nil.yaml	servercodec-readrequestbody-unhandled-nil	go	Acotado, sin indicios de sobre-generalizacion	Si, pasa semgrep --test	Si (WARNING/HIGH, CWE coherente con el mensaje)	Ninguna detecta
go/string-to-int-signedness-cast.yaml	string-to-int-signedness-cast	go	Acotado, sin indicios de sobre-generalizacion	Si, pasa semgrep --test	Si (WARNING/HIGH, CWE coherente con el mensaje)	Ninguna detecta
go/sync-mutex-value-copied.yaml	sync-mutex-value-copied	go	Acotado, sin indicios de sobre-generalizacion	Si, pasa semgrep --test	Si (ERROR/HIGH, CWE coherente con el mensaje)	Ninguna detecta
go/unmarshal_tag_is_dash.yaml	unmarshal-tag-is-dash	go	Correcto y estrecho	Si pasa semgrep --test	Si (CWE-172 coherente: un typo en el tag json:"-,..." puede filtrar campos que debian quedar ocultos, ej. passwords/tokens)	Referencia poco https://blog.portada del blog tema
go/unmarshal_tag_is_omitempty.yaml	unmarshal-tag-is-omitempty	go	Correcto y estrecho	Si pasa semgrep --test	Si (CWE-172 coherente: falta la coma en json:" ,omitempty", el campo se serializa siempre con nombre literal "omitempty" en vez de omitirse condicionalmente)	Misma referenci: dash (portada de

Fichero	ID	Lenguaje	Patron (amplitud)	Tests (semgrep - --test)	Severity/Confidence coherente	Sospechoso
go/unsafe-dll-loading.yaml	unsafe-dll-loading	go	Acotado, sin indicios de sobre-generalizacion	Si, pasa semgrep --test	Si (ERROR/HIGH, CWE coherente con el mensaje)	Ninguna detecta
go/waitgroup-add-called-inside-goroutine.yaml	waitgroup-add-called-inside-goroutine	go	Acotado, sin indicios de sobre-generalizacion	Si, pasa semgrep --test	Si (ERROR/MEDIUM, CWE coherente con el mensaje)	Ninguna detecta
go/waitgroup-wait-inside-loop.yaml	waitgroup-wait-inside-loop	go	Acotado, sin indicios de sobre-generalizacion	Si, pasa semgrep --test	Si (WARNING/MEDIUM, CWE coherente con el mensaje)	Ninguna detecta
hcl/nomad/docker-hardcoded-password.yaml	docker-hardcoded-password	hcl	Acotado, sin indicios de sobre-generalizacion	Si, pasa semgrep --test	Si (WARNING/HIGH, CWE coherente con el mensaje)	Ninguna detecta
hcl/nomad/docker-privileged-mode.yaml	docker-privileged-mode	hcl	Acotado, sin indicios de sobre-generalizacion	Si, pasa semgrep --test	Si (WARNING/HIGH, CWE coherente con el mensaje)	Ninguna detecta
hcl/nomad/podman-tls-verify-disabled.yaml	podman-tls-verify-disabled	hcl	Acotado, sin indicios de sobre-generalizacion	Si, pasa semgrep --test	Si (WARNING/HIGH, CWE coherente con el mensaje)	Ninguna detecta
hcl/nomad/root-user.yaml	root-user	hcl	Acotado, sin indicios de sobre-generalizacion	Si, pasa semgrep --test	Si (WARNING/HIGH, CWE coherente con el mensaje)	Ninguna detecta
hcl/nomad/tls-hostname-verification-disabled.yaml	tls-hostname-verification-disabled	hcl	Acotado, sin indicios de sobre-generalizacion	Si, pasa semgrep --test	Si (WARNING/HIGH, CWE coherente con el mensaje)	Ninguna detecta
hcl/terraform/aws-oidc-role-policy-duplicate-condition.yaml	aws-oidc-role-policy-duplicate-condition	hcl	Acotado, sin indicios de sobre-generalizacion	Si, pasa semgrep --test	Si (WARNING/HIGH, CWE coherente con el mensaje)	Ninguna detecta
hcl/terraform/aws-oidc-role-policy-missing-sub.yaml	aws-oidc-role-policy-missing-sub	hcl	Acotado, sin indicios de sobre-generalizacion	Si, pasa semgrep --test	Si (WARNING/HIGH, CWE coherente con el mensaje)	Ninguna detecta

Fichero	ID	Lenguaje	Patron (amplitud)	Tests (semgrep - --test)	Severity/Confidence coherente	Sospechoso
hcl/terraform/vault-hardcoded-token.yaml	vault-hardcoded-token	hcl	Acotado, sin indicios de sobre-generalizacion	Si, pasa semgrep --test	Si (WARNING/HIGH, CWE coherente con el mensaje)	Ninguna detecta
hcl/terraform/vault-skip-tls-verify.yaml	vault-skip-tls-verify	hcl	Acotado, sin indicios de sobre-generalizacion	Si, pasa semgrep --test	Si (WARNING/HIGH, CWE coherente con el mensaje)	Ninguna detecta
javascript/apollo-graphql/schema-directives.yaml	schema-directives	js, ts	Acotado, sin indicios de sobre-generalizacion	Si, pasa semgrep --test	Si (ERROR/MEDIUM, CWE coherente con el mensaje)	Ninguna detecta
javascript/apollo-graphql/use-of-graphql-upload.yaml	use-of-graphql-upload	js, ts	Acotado, sin indicios de sobre-generalizacion	Si, pasa semgrep --test	Si (WARNING/LOW, CWE coherente con el mensaje)	Ninguna detecta
javascript/apollo-graphql/v3-cors-audit.yaml	v3-potentially-bad-cors	js, ts	Acotado, sin indicios de sobre-generalizacion	Si, pasa semgrep --test	Si (WARNING/LOW, CWE coherente con el mensaje)	Ninguna detecta
javascript/apollo-graphql/v3-cors-express.yaml	v3-express-bad-cors	js, ts	Acotado, sin indicios de sobre-generalizacion	Si, pasa semgrep --test	Si (ERROR/MEDIUM, CWE coherente con el mensaje)	Ninguna detecta
javascript/apollo-graphql/v3-cors-express.yaml	v3-express-no-cors	js, ts	Acotado, sin indicios de sobre-generalizacion	Si, pasa semgrep --test	Si (WARNING/HIGH, CWE coherente con el mensaje)	Ninguna detecta
javascript/apollo-graphql/v3-cors.yaml	v3-bad-cors	js, ts	Acotado, sin indicios de sobre-generalizacion	Si, pasa semgrep --test	Si (ERROR/MEDIUM, CWE coherente con el mensaje)	Ninguna detecta
javascript/apollo-graphql/v3-cors.yaml	v3-no-cors	js, ts	Acotado, sin indicios de sobre-generalizacion	Si, pasa semgrep --test	Si (WARNING/HIGH, CWE coherente con el mensaje)	Ninguna detecta
javascript/apollo-graphql/v3-csrf-prevention.yaml	v3-csrf-prevention	js, ts	Acotado, sin indicios de sobre-generalizacion	Si, pasa semgrep --test	Si (ERROR/HIGH, CWE coherente con el mensaje)	Ninguna detecta

Fichero	ID	Lenguaje	Patron (amplitud)	Tests (semgrep - -test)	Severity/Confidence coherente	Sospechoso
javascript/apollo-graphql/v4-csrf-prevention.yaml	v4-csrf-prevention	js, ts	Acotado, sin indicios de sobre-generalizacion	Si, pasa semgrep --test	Si (ERROR/HIGH, CWE coherente con el mensaje)	Ninguna detecta
jvm/gc-call.yaml	gc-call	java, kotlin	Correcto y estrecho	Si pasa semgrep --test	category=best-practice, CWE=None -- no es una regla de seguridad; referencia es una pregunta de StackOverflow (unica fuente, no oficial)	Ninguna
jvm/mongo-hostname-verification-disabled.yaml	mongo-hostname-verification-disabled	java, kotlin	Acotado, sin indicios de sobre-generalizacion	Si, pasa semgrep --test	Si (WARNING/HIGH, CWE coherente con el mensaje)	Ninguna detecta
python/automatic-memory-pinning.yaml	automatic-memory-pinning	python	Correcto y estrecho	Si pasa semgrep --test	No: CWE-676 'Use of Potentially Dangerous Function' no encaja con el problema real (una recomendacion de rendimiento/UB al no usar pin_memory automatico, no una funcion peligrosa)	Ninguna
python/lxml-in-pandas.yaml	lxml-in-pandas	python	Acotado, sin indicios de sobre-generalizacion	Si, pasa semgrep --test	Si (ERROR/HIGH, CWE coherente con el mensaje)	Ninguna detecta
python/msgpack-numpy.yaml	msgpack-numpy	python	Acotado, sin indicios de sobre-generalizacion	Si, pasa semgrep --test	Si (ERROR/MEDIUM, CWE coherente con el mensaje)	Ninguna detecta
python/numpy-distutils.yaml	numpy-distutils	python	Correcto y estrecho	Si pasa semgrep --test	Si	Referencia rota: https://numpy.org/doc/1.16/user/known_issues.html devuelve HTTP 4 docs)
python/numpy-f2py-compile.yaml	numpy-f2py-compile	python	Acotado, sin indicios de sobre-generalizacion	Si, pasa semgrep --test	Si (ERROR/MEDIUM, CWE coherente con el mensaje)	Ninguna detecta

Fichero	ID	Lenguaje	Patron (amplitud)	Tests (semgrep - --test)	Severity/Confidence coherente	Sospechoso
python/numpy-in-pytorch-datasets.yaml	numpy-in-pytorch-datasets	python	Acotado, sin indicios de sobre-generalizacion	Si, pasa semgrep --test	Si (WARNING/HIGH, CWE coherente con el mensaje)	Ninguna detecta
python/numpy-in-pytorch-modules.yaml	numpy-in-pytorch-modules	python	Correcto y razonable	Si pasa semgrep --test	category=performance, sin CWE -- no es una regla de seguridad	Referencia recicl datasets.yaml (h aleatoriedad dup
python/numpy-load-library.yaml	numpy-load-library	python	Acotado, sin indicios de sobre-generalizacion	Si, pasa semgrep --test	Si (ERROR/MEDIUM, CWE coherente con el mensaje)	Ninguna detecta
python/onnx-session-options.yaml	onnx-session-options	python	Acotado, sin indicios de sobre-generalizacion	Si, pasa semgrep --test	Si (ERROR/MEDIUM, CWE coherente con el mensaje)	Ninguna detecta
python/pandas-eval.yaml	pandas-eval	python	Acotado, sin indicios de sobre-generalizacion	Si, pasa semgrep --test	Si (ERROR/LOW, CWE coherente con el mensaje)	Ninguna detecta
python/pickles-in-keras-deprecation.yaml	pickles-in-keras-deprecation	python	Acotado, sin indicios de sobre-generalizacion	Si, pasa semgrep --test	Si (WARNING/MEDIUM, CWE coherente con el mensaje)	Ninguna detecta
python/pickles-in-keras.yaml	pickles-in-keras	python	Acotado, sin indicios de sobre-generalizacion	Si, pasa semgrep --test	Si (ERROR/MEDIUM, CWE coherente con el mensaje)	Ninguna detecta
python/pickles-in-numpy.yaml	pickles-in-numpy	python	Acotado, sin indicios de sobre-generalizacion	Si, pasa semgrep --test	Si (ERROR/MEDIUM, CWE coherente con el mensaje)	Ninguna detecta
python/pickles-in-pandas.yaml	pickles-in-pandas	python	Acotado, sin indicios de sobre-generalizacion	Si, pasa semgrep --test	Si (ERROR/MEDIUM, CWE coherente con el mensaje)	Ninguna detecta
python/pickles-in-pytorch-distributed.yaml	pickles-in-pytorch-distributed	python	Acotado, sin indicios de sobre-generalizacion	Si, pasa semgrep --test	Si (ERROR/MEDIUM, CWE coherente con el mensaje)	Ninguna detecta

Fichero	ID	Lenguaje	Patron (amplitud)	Tests (semgrep - --test)	Severity/Confidence coherente	Sospechoso
python/pickles-in-pytorch.yaml	pickles-in-pytorch	python	Acotado, sin indicios de sobre-generalizacion	Si, pasa semgrep --test	Si (ERROR/MEDIUM, CWE coherente con el mensaje)	Ninguna detecta
python/pickles-in-tensorflow.yaml	pickles-in-tensorflow	python	Acotado, sin indicios de sobre-generalizacion	Si, pasa semgrep --test	Si (ERROR/MEDIUM, CWE coherente con el mensaje)	Ninguna detecta
python/pytorch-classes-load-library.yaml	pytorch-classes-load-library	python	Acotado, sin indicios de sobre-generalizacion	Si, pasa semgrep --test	Si (ERROR/MEDIUM, CWE coherente con el mensaje)	Ninguna detecta
python/pytorch-package.yaml	pytorch-package	python	Acotado, sin indicios de sobre-generalizacion	Si, pasa semgrep --test	Si (WARNING/LOW, CWE coherente con el mensaje)	Ninguna detecta
python/pytorch-tensor.yaml	pytorch-tensor	python	Correcto y razonable	Si, pasa semgrep --test	category=performance, sin CWE -- no es una regla de seguridad	Ninguna
python/scikit-joblib-load.yaml	scikit-joblib-load	python	Acotado, sin indicios de sobre-generalizacion	Si, pasa semgrep --test	Si (ERROR/MEDIUM, CWE coherente con el mensaje)	Ninguna detecta
python/tarfile-extractall-traversal.yaml	tarfile-extractall-traversal	python	Acotado, sin indicios de sobre-generalizacion	Si, pasa semgrep --test	Si (ERROR/MEDIUM, CWE coherente con el mensaje)	Ninguna detecta
python/tensorflow-load-library.yaml	tensorflow-load-library	python	Acotado, sin indicios de sobre-generalizacion	Si, pasa semgrep --test	Si (ERROR/MEDIUM, CWE coherente con el mensaje)	Ninguna detecta
python/waiting-with-pytorch-distributed.yaml	waiting-with-pytorch-distributed	python	Acotado, sin indicios de sobre-generalizacion	Si, pasa semgrep --test	Si (WARNING/MEDIUM, CWE coherente con el mensaje)	Ninguna detecta

Fichero	ID	Lenguaje	Patron (amplitud)	Tests (semgrep - --test)	Severity/Confidence coherente	Sospechoso
rs/panic-in-function-returning- result.yaml	panic-in- function- returning-result	rust	Acotado, sin indicios de sobre- generalizacion	Si, pasa semgrep --test	Si (WARNING/HIGH, CWE coherente con el mensaje)	Ninguna detecta
ruby/action-dispatch-insecure- ssl.yaml	action-dispatch- insecure-ssl	ruby	Acotado, sin indicios de sobre- generalizacion	Si, pasa semgrep --test	Si (WARNING/HIGH, CWE coherente con el mensaje)	Ninguna detecta
ruby/action-mailer-insecure-tls.yaml	action-mailer- insecure-tls	ruby	Acotado, sin indicios de sobre- generalizacion	Si, pasa semgrep --test	Si (WARNING/HIGH, CWE coherente con el mensaje)	Ninguna detecta
ruby/active-record-encrypts- misorder.yaml	active-record- encrypts- misorder	ruby	Acotado, sin indicios de sobre- generalizacion	Si, pasa semgrep --test	Si (WARNING/HIGH, CWE coherente con el mensaje)	Ninguna detecta
ruby/active-record-hardcoded- encryption-key.yaml	active-record- hardcoded- encryption-key	ruby	Acotado, sin indicios de sobre- generalizacion	Si, pasa semgrep --test	Si (WARNING/HIGH, CWE coherente con el mensaje)	Ninguna detecta
ruby/faraday-disable- verification.yaml	faraday-disable- verification	ruby	Acotado, sin indicios de sobre- generalizacion	Si, pasa semgrep --test	Si (WARNING/HIGH, CWE coherente con el mensaje)	Ninguna detecta
ruby/global-timeout.yaml	global-timeout	ruby	Acotado, sin indicios de sobre- generalizacion	Si, pasa semgrep --test	Si (WARNING/HIGH, CWE coherente con el mensaje)	Ninguna detecta
ruby/insecure-rails-cookie-session- store.yaml	insecure-rails- cookie-session- store	ruby	Demasiado amplio por un error conceptual, no por diseno	Si pasa semgrep --test, pero el propio fixture .rb contiene el mismo error que el rule (ver 'sospechoso')	No coherente: CWE- 345 (autenticidad) mezclado con un valor de configuracion que no existe en Rails	El pattern-not de :secure, pero : same_site en R secure es un fla Esto significa qu cumple con codi sobre practicam configurado de l same_site: :strict
ruby/json-create-deserialization.yaml	json-create- deserialization	ruby	Acotado, sin indicios de sobre- generalizacion	Si, pasa semgrep --test	Si (INFO/LOW, CWE coherente con el mensaje)	Ninguna detecta

Fichero	ID	Lenguaje	Patron (amplitud)	Tests (semgrep - --test)	Severity/Confidence coherente	Sospechoso
ruby/marshal-load-method.yaml	marshal-load-method	ruby	Acotado, sin indicios de sobre-generalizacion	Si, pasa semgrep --test	Si (INFO/LOW, CWE coherente con el mensaje)	Ninguna detecta
ruby/rails-cache-store-marshal.yaml	rails-cache-store-marshal	ruby	Acotado, sin indicios de sobre-generalizacion	Si, pasa semgrep --test	Si (WARNING/MEDIUM, CWE coherente con el mensaje)	Ninguna detecta
ruby/rails-cookie-attributes.yaml	rails-cookie-attributes	ruby	Acotado, sin indicios de sobre-generalizacion	Si, pasa semgrep --test	Si (WARNING/HIGH, CWE coherente con el mensaje)	Ninguna detecta
ruby/rails-params-json.yaml	rails-params-json	ruby	Acotado, sin indicios de sobre-generalizacion	Si, pasa semgrep --test	Si (WARNING/LOW, CWE coherente con el mensaje)	Ninguna detecta
ruby/rest-client-disable-verification.yaml	rest-client-disable-verification	ruby	Acotado, sin indicios de sobre-generalizacion	Si, pasa semgrep --test	Si (WARNING/HIGH, CWE coherente con el mensaje)	Ninguna detecta
ruby/ruby-saml-skip-validation.yaml	ruby-saml-skip-validation	ruby	Acotado, sin indicios de sobre-generalizacion	Si, pasa semgrep --test	Si (WARNING/HIGH, CWE coherente con el mensaje)	Ninguna detecta
ruby/yaml-unsafe-load.yaml	yaml-unsafe-load	ruby	Acotado, sin indicios de sobre-generalizacion	Si, pasa semgrep --test	Si (WARNING/HIGH, CWE coherente con el mensaje)	Ninguna detecta
swift/insecure-url-host-hassuffix-check.yaml	insecure-url-host-hassuffix-check	swift	Correcto, con multiples variantes bien acotadas via metavariante-regex	Si pasa semgrep --test	Si	Una de las 3 refe (https://pentest.vulnerabilitycheck.com/) tema de la regla vulnerabilidades erroneo en meta

Fichero	ID	Lenguaje	Patron (amplitud)	Tests (semgrep - --test)	Severity/Confidence coherente	Sospechoso
yaml/ansible/apt-key-unencrypted-url.yaml	apt-key-unencrypted-url	yaml	Acotado, sin indicios de sobre-generalizacion	Si, pasa semgrep --test	Si (WARNING/HIGH, CWE coherente con el mensaje)	Ninguna detecta
yaml/ansible/apt-key-validate-certs-disabled.yaml	apt-key-validate-certs-disabled	yaml	Acotado, sin indicios de sobre-generalizacion	Si, pasa semgrep --test	Si (WARNING/HIGH, CWE coherente con el mensaje)	Ninguna detecta
yaml/ansible/apt-unencrypted-url.yaml	apt-unencrypted-url	yaml	Acotado, sin indicios de sobre-generalizacion	Si, pasa semgrep --test	Si (WARNING/HIGH, CWE coherente con el mensaje)	Ninguna detecta
yaml/ansible/dnf-unencrypted-url.yaml	dnf-unencrypted-url	yaml	Acotado, sin indicios de sobre-generalizacion	Si, pasa semgrep --test	Si (WARNING/HIGH, CWE coherente con el mensaje)	Ninguna detecta
yaml/ansible/dnf-validate-certs-disabled.yaml	dnf-validate-certs-disabled	yaml	Acotado, sin indicios de sobre-generalizacion	Si, pasa semgrep --test	Si (WARNING/HIGH, CWE coherente con el mensaje)	Ninguna detecta
yaml/ansible/get-url-unencrypted-url.yaml	get-url-unencrypted-url	yaml	Acotado, sin indicios de sobre-generalizacion	Si, pasa semgrep --test	Si (WARNING/HIGH, CWE coherente con el mensaje)	Ninguna detecta
yaml/ansible/get-url-validate-certs-disabled.yaml	get-url-validate-certs-disabled	yaml	Acotado, sin indicios de sobre-generalizacion	Si, pasa semgrep --test	Si (WARNING/HIGH, CWE coherente con el mensaje)	Ninguna detecta
yaml/ansible/rpm-key-unencrypted-url.yaml	rpm-key-unencrypted-url	yaml	Acotado, sin indicios de sobre-generalizacion	Si, pasa semgrep --test	Si (WARNING/HIGH, CWE coherente con el mensaje)	Ninguna detecta
yaml/ansible/rpm-key-validate-certs-disabled.yaml	rpm-key-validate-certs-disabled	yaml	Acotado, sin indicios de sobre-generalizacion	Si, pasa semgrep --test	Si (WARNING/HIGH, CWE coherente con el mensaje)	Ninguna detecta
yaml/ansible/unarchive-unencrypted-url.yaml	unarchive-unencrypted-url	yaml	Acotado, sin indicios de sobre-generalizacion	Si, pasa semgrep --test	Si (WARNING/HIGH, CWE coherente con el mensaje)	Ninguna detecta

Fichero	ID	Lenguaje	Patron (amplitud)	Tests (semgrep - --test)	Severity/Confidence coherente	Sospechoso
yaml/ansible/unarchive-validate-certs-disabled.yaml	unarchive-validate-certs-disabled	yaml	Acotado, sin indicios de sobre-generalizacion	Si, pasa semgrep --test	Si (WARNING/HIGH, CWE coherente con el mensaje)	Ninguna detecta
yaml/ansible/wrm-cert-validation-ignore.yaml	wrm-cert-validation-ignore	yaml	Acotado, sin indicios de sobre-generalizacion	Si, pasa semgrep --test	Si (WARNING/HIGH, CWE coherente con el mensaje)	Ninguna detecta
yaml/ansible/yum-unencrypted-url.yaml	yum-unencrypted-url	yaml	Acotado, sin indicios de sobre-generalizacion	Si, pasa semgrep --test	Si (WARNING/HIGH, CWE coherente con el mensaje)	Ninguna detecta
yaml/ansible/yum-validate-certs-disabled.yaml	yum-validate-certs-disabled	yaml	Acotado, sin indicios de sobre-generalizacion	Si, pasa semgrep --test	Si (WARNING/HIGH, CWE coherente con el mensaje)	Ninguna detecta
yaml/ansible/zypper-repository-unencrypted-url.yaml	zypper-repository-unencrypted-url	yaml	Acotado, sin indicios de sobre-generalizacion	Si, pasa semgrep --test	Si (WARNING/HIGH, CWE coherente con el mensaje)	Ninguna detecta
yaml/ansible/zypper-unencrypted-url.yaml	zypper-unencrypted-url	yaml	Acotado, sin indicios de sobre-generalizacion	Si, pasa semgrep --test	Si (WARNING/HIGH, CWE coherente con el mensaje)	Ninguna detecta
yaml/docker-compose/port-all-interfaces.yaml	port-all-interfaces	yaml	Demasiado amplio por diseno: dispara en cualquier puerto publicado que no empiece por 127., que es el caso mas comun en docker-compose (necesitas exponer el puerto para que el contenedor sea alcanzable)	Si pasa semgrep --test	Si (LOW confidence declarado, coherente con el ruido esperado)	Ninguna
yaml/github-actions/aws-secret-key.yaml	aws-secret-key	yaml	Acotado, sin indicios de sobre-generalizacion	Si, pasa semgrep --test	Si (WARNING/HIGH, CWE coherente con el mensaje)	Ninguna detecta
yaml/github-actions/azure-principal-secret.yaml	azure-principal-secret	yaml	Acotado, sin indicios de sobre-generalizacion	Si, pasa semgrep --test	Si (WARNING/HIGH, CWE coherente con el mensaje)	Ninguna detecta

Fichero	ID	Lenguaje	Patron (amplitud)	Tests (semgrep --test)	Severity/Confidence coherente	Sospechoso
yaml/github-actions/gcp-credentials-json.yaml	gcp-credentials-json	yaml	Acotado, sin indicios de sobre-generalizacion	Si, pasa semgrep --test	Si (WARNING/HIGH, CWE coherente con el mensaje)	Ninguna detecta
yaml/github-actions/jfrog-hardcoded-credential.yaml	jfrog-hardcoded-credential	yaml	Acotado, sin indicios de sobre-generalizacion	Si, pasa semgrep --test	Si (WARNING/HIGH, CWE coherente con el mensaje)	Ninguna detecta
yaml/github-actions/pypi-publish-password.yaml	pypi-publish-password	yaml	Acotado, sin indicios de sobre-generalizacion	Si, pasa semgrep --test	Si (WARNING/HIGH, CWE coherente con el mensaje)	Ninguna detecta
yaml/github-actions/rubygems-publish-key.yaml	rubygems-publish-key	yaml	Acotado, sin indicios de sobre-generalizacion	Si, pasa semgrep --test	Si (WARNING/HIGH, CWE coherente con el mensaje)	Ninguna detecta
yaml/github-actions/vault-token.yaml	vault-token	yaml	Acotado, sin indicios de sobre-generalizacion	Si, pasa semgrep --test	Si (WARNING/HIGH, CWE coherente con el mensaje)	Ninguna detecta

Reglas propias nuevas (no provienen de trailofbits/semgrep-rules)

Propuestas por decision del usuario (2026-08-04) para cubrir huecos de alto impacto no cubiertos por el set importado. Cada una escrita con YAML + fixture de test propios, verificadas con semgrep --test (5/5 passed) antes de aprobar.

Fichero	ID	Lenguaje	CWE	Veredicto	Justificacion
custom/jvm/java-insecure-deserialization-readobject.yaml	java-insecure-deserialization-readobject	java	CWE-502 (RCE via deserializacion)	APROBAR	Ningun hueco cubierto por trailofbits para RCE por deserializacion Java (gadget chains). Test propio pasa.
custom/python/python-command-injection-shell-true.yaml	python-command-injection-shell-true	python	CWE-78 (inyeccion de comandos OS, RCE)	APROBAR	El set importado no tenia ninguna regla de inyeccion de comandos. Test propio pasa.
custom/javascript/javascript-jwt-verify-disabled.yaml	javascript-jwt-verify-disabled	js, ts	CWE-347 (bypass de autenticacion)	APROBAR	Cubre el bypass clasico de JWT (jwt.decode sin verificar / algoritmo none). Test propio pasa.
custom/ruby/ruby-sql-injection-raw-query.yaml	ruby-sql-injection-raw-query	ruby	CWE-89 (inyeccion SQL)	APROBAR	El set importado tiene muchas reglas de Rails pero ninguna de inyeccion SQL. Test propio pasa.
custom/python/python-ssrf-unvalidated-url.yaml	python-ssrf-unvalidated-url	python	CWE-918 (SSRF)	APROBAR	confidence:LOW declarado a proposito (patron amplio por diseno, igual que port-all-interfaces). Test propio pasa.

Segunda tanda (decision del usuario, 2026-08-04): 3 reglas C/C++, 3 PHP, 3 C#/NET, 2 PowerShell. Todas verificadas con semgrep --test (15/15 checks passed tras corregir bugs de patron encontrados durante la validacion).

Fichero	ID	Lenguaje	CWE	Veredicto	Nota de validacion
custom/c/c-buffer-overflow-unbounded-copy.yaml	c-buffer-overflow-unbounded-copy	c, cpp	CWE-120/CWE-787 (buffer overflow, RCE)	APROBAR	Test propio pasa sin cambios.

Fichero	ID	Lenguaje	CWE	Veredicto	Nota de validacion
custom/c/c-format-string-vulnerability.yaml	c-format-string-vulnerability	c, cpp	CWE-134 (format string)	APROBAR	Test propio pasa sin cambios.
custom/c/c-use-after-free.yaml	c-use-after-free	c, cpp	CWE-416 (use-after-free)	APROBAR	confidence:LOW (sin dataflow real). Se corrigio la posicion de la anotacion del test: Semgrep reporta el hallazgo en la linea del <code>free()</code> , no en la linea de uso posterior.
custom/php/php-insecure-unserialize.yaml	php-insecure-unserialize	php	CWE-502 (PHP Object Injection, RCE)	APROBAR	Test propio pasa sin cambios.
custom/php/php-file-inclusion-dynamic-path.yaml	php-file-inclusion-dynamic-path	php	CWE-98 (LFI/RFI, RCE)	APROBAR	Test propio pasa sin cambios.
custom/php/php-eval-dynamic-code.yaml	php-eval-dynamic-code	php	CWE-95 (eval injection, RCE)	APROBAR	Test propio pasa sin cambios.
custom/csharp/csharp-insecure-binaryformatter-deserialize.yaml	csharp-insecure-binaryformatter-deserialize	csharp	CWE-502 (RCE, equivalente a Java readObject)	APROBAR	Se corrigio el patron: faltaba la variante <code>var \$BF = new BinaryFormatter(...)</code> (declaracion con <code>var</code>), solo cubria reasignacion simple.
custom/csharp/csharp-sql-injection-sqlcommand.yaml	csharp-sql-injection-sqlcommand	csharp	CWE-89 (inyeccion SQL)	APROBAR	Test propio pasa sin cambios.
custom/csharp/csharp-xxe-dtd-processing-enabled.yaml	csharp-xxe-dtd-processing-enabled	csharp	CWE-611 (XXE)	APROBAR	Test propio pasa sin cambios.
custom/powershell/powershell-invoke-expression-dynamic.yaml	powershell-invoke-expression-dynamic	generic (PowerShell no soportado en Semgrep OSS sin plugin de pago)	CWE-95 (eval injection, RCE)	APROBAR	<code>languages: [powershell]</code> requiere <code>semgrep install-semgrep-pro + semgrep login</code> (cuenta), no disponible en este entorno. Reescrita en modo <code>generic</code> (mismo enfoque que usa <code>trailofbits</code> para <code>curl/wget/ssh</code>). Se simplifico para marcar TODO uso de <code>Invoke-Expression/iex</code> sin excepcion por literal, igual que la regla oficial de Microsoft PSScriptAnalyzer (<code>AvoidUsingInvokeExpression</code>). Se anadio <code>generic_ellipsis_max_span: 0</code> (bug encontrado: el <code>...</code> sin este limite se "tragaba" varias lineas de golpe).
custom/powershell/powershell-download-and-execute.yaml	powershell-download-and-execute	generic (mismo motivo que la anterior)	CWE-494 (descarga y ejecucion sin verificar integridad)	APROBAR	Mismos ajustes que la regla anterior (modo <code>generic + generic_ellipsis_max_span: 0</code>).

Tercera tanda (decision del usuario, 2026-08-04): cobertura para Swift, Rust, Java, Regex/connection-strings, C#/.NET, PHP y C/C++. 15 reglas, todas verificadas con `semgrep --test` (30/30 checks passed tras corregir 4 bugs de patron/test encontrados durante la validacion).

Fichero	ID	Lenguaje	CWE	Veredicto	Nota de validacion
custom/swift/swift-urlsession-certificate-pinning-bypass.yaml	swift-urlsession-certificate-pinning-bypass	swift	CWE-295 (MITM)	APROBAR	Se corrigio comilla YAML faltante (patron con <code>trust:</code> sin comillas rompia el parseo).
custom/swift/swift-wkwebview-evaluatejavascript-injection.yaml	swift-wkwebview-evaluatejavascript-injection	swift	CWE-79 (XSS en WKWebView)	APROBAR	Test propio pasa sin cambios.
custom/rust/rust-command-injection-shell.yaml	rust-command-injection-shell	rust	CWE-78 (RCE)	APROBAR	Test propio pasa sin cambios.

Fichero	ID	Lenguaje	CWE	Veredicto	Nota de validacion
custom/rust/rust-request-tls-verification-disabled.yaml	rust-request-tls-verification-disabled	rust	CWE-295 (MITM)	APROBAR	Se corrigio la posicion de la anotacion del test (Semgrep reporta el hallazgo donde empieza la cadena de llamadas <code>.builder()</code> , no en la linea del metodo especifico).
custom/jvm/java-sql-injection-statement.yaml	java-sql-injection-statement	java	CWE-89 (inyeccion SQL)	APROBAR	Test propio pasa sin cambios.
custom/jvm/java-xxe-documentbuilderfactory.yaml	java-xxe-documentbuilderfactory	java	CWE-611 (XXE)	APROBAR	confidence:LOW (sin dataflow real, similar a c-use-after-free).
custom/jvm/java-weak-hash-algorithm.yaml	java-weak-hash-algorithm	java	CWE-327 (criptografia debil)	APROBAR	Test propio pasa sin cambios.
custom/regex/sqlserver-insecure-connection-encryption.yaml	sqlserver-insecure-connection-encryption	regex	CWE-295 (MITM)	APROBAR	Llena el hueco de SQL Server (mysql/postgres ya cubiertos por trailofbits, SQL Server no).
custom/regex/connection-string-hardcoded-password.yaml	connection-string-hardcoded-password	regex	CWE-798 (credenciales hardcodeadas)	APROBAR	confidence:LOW. Se ajusto el regex para no marcar como "hardcodeada" una contraseña que en realidad es una variable de entorno interpolada (<code>\${VAR}</code>).
custom/csharp/csharp-command-injection-processtart.yaml	csharp-command-injection-processtart	csharp	CWE-78 (RCE)	APROBAR	Se corrigio un pattern-not que excluia por error el caso peligroso real (excluia si el ejecutable era literal, sin mirar si los argumentos eran dinamicos, que es lo que importa).
custom/csharp/csharp-path-traversal-pathcombine.yaml	csharp-path-traversal-pathcombine	csharp	CWE-22 (path traversal)	APROBAR	confidence:LOW (Path.Combine no sanea ".." por diseno). Test propio pasa sin cambios.
custom/php/php-sql-injection-mysqli-query.yaml	php-sql-injection-mysqli-query	php	CWE-89 (inyeccion SQL)	APROBAR	Se corrigio sintaxis: llamada a metodo en PHP es <code>-></code> , no <code>.</code> (error de mezclar convenciones de otros lenguajes).
custom/php/php-command-injection-exec.yaml	php-command-injection-exec	php	CWE-78 (RCE)	APROBAR	Test propio pasa sin cambios.
custom/c/c-command-injection-system.yaml	c-command-injection-system	c, cpp	CWE-78 (RCE)	APROBAR	Test propio pasa sin cambios.
custom/c/c-integer-overflow-malloc-size.yaml	c-integer-overflow-malloc-size	c, cpp	CWE-190 (integer overflow, RCE)	APROBAR	confidence:LOW (no hay forma de saber estaticamente si la multiplicacion esta ya validada).

Importacion masiva de repositorios de terceros (decision del usuario, 2026-08-04)

Peticion original: importar todas las reglas de [semgrep/semgrep-rules](#), [tuannq2299/semgrep-rules](#), [iosifache/semgrep-rules-manager](#) y [j3ssie/curated-semgrep-rules](#) (~2.988 reglas totales, [iosifache/semgrep-rules-manage](#) -- sin la r final -- no existe, se corrigio a [semgrep-rules-manager](#)).

Criterio aplicado (decidido con el usuario tras comprobar que la revision manual fila-por-fila no es viable a esta escala): se aprueba una regla solo si (1) pasa `semgrep --test`, (2) `metadata.category == security`, y (3) `metadata.confidence` no es `LOW`. Sin lectura manual de patrones individual (inviable en ~3.000 reglas); esto es un proxy automatico, no una revision humana como la de la Fase 1.

Hallazgo clave: [iosifache/semgrep-rules-manager](#) no es un repositorio de reglas

Es una herramienta Python que descarga reglas de **14 fuentes de terceros bajo demanda**. Se inspecciono su `sources.yaml`: de esas 14 fuentes, [community](#) (=registro oficial) y [trailofbits](#) ya estaban cubiertas, y otras 8 ([gitlab](#), [0xdea](#), [elttam](#), [kondukto](#), [dgryski](#), [dotta](#), [hashicorp](#), [decurity](#), [mindedsecurity](#)) ya estaban agregadas dentro de [j3ssie/curated-semgrep-rules](#). Solo 3 fuentes eran nuevas: [akabei](#), [atlassian-labs](#), [apiiro](#).

Aviso de licencia (no llego a importarse): [decurity/semgrep-smart-contracts](#) (una de las 14 fuentes) usa licencia **CC BY-NC-SA 4.0 (No Comercial)**, mas restrictiva que la AGPL de trailofbits. Si en el futuro se importa, requiere exclusion o marcado aparte.

Resultado por fuente

Fuente	Reglas totales	Resultado tras aplicar el criterio
semgrep/semgrep-rules (oficial)	~2.080	553 aprobadas (ver desglose abajo)

Fuente	Reglas totales	Resultado tras aplicar el criterio
j3ssie/curated-semgrep-rules	821	0 nuevas (su unica carpeta que pasa test es una copia desactualizada de trailofbits, ya cubierta; el resto -- Oxdea, android-security, dgryski, elttam, federicodotta, gitlab, hashicorp, kondukto, ligurio, semgrep-smart-contracts -- falla semgrep --test a nivel de carpeta)
tuannq2299/semgrep-rules	87	0 (sus 2 carpetas, Java y csharp, fallan; ademas 2 ficheros YAML rotos que ni parsean)
iosifache -> akabe1	47	0 (sin ningun fichero de test, no se puede verificar)
iosifache -> atlassian-labs	11	0 (sin ningun fichero de test)
iosifache -> apiiro	101 (68 con test)	0 (0/68 pasan su propio test)

Metodologia para el registro oficial (por que no es un simple "semgrep --test.")

Un solo fichero YAML roto, un fichero de test mal referenciado, o una regla que necesita el plugin de pago (Apex, Elixir, PowerShell) **hace fallar la ejecucion completa de semgrep --test para todo el arbol**, no solo esa regla. Para evitar perder miles de reglas buenas por culpa de una sola rota, se testeo carpeta por carpeta (por lenguaje), y para las carpetas grandes que fallaron (python, terraform, go, generic, csharp, solidity, typescript) se bajo un nivel mas (por framework/proveedor dentro de cada lenguaje).

Carpetas/subcarpetas que NO se pudieron testear por este motivo y se descartaron en bloque (posible trabajo futuro si se quiere profundizar mas): [apex](#) y [elixir](#) completos (necesitan plugin Pro de pago, igual que PowerShell), [python/lang](#) (134 reglas), [terraform/aws+azure+gcp](#) (345 de 364 reglas), [go/lang](#) (62 reglas), [generic/secrets](#) (225 reglas -- la mas lamentable de perder, es deteccion de secretos hardcoded), [csharp/dotnet+lang](#) (51 de 52 reglas), [solidity/security](#) (35 de 50), [typescript/react](#) (18 de 30).

Desglose de las 553 reglas aprobadas por lenguaje

Lenguaje	Reglas aprobadas
Python	159
JavaScript/TypeScript	100
Java/Kotlin	84
Ruby	53
Generic	39
YAML	28
Go	27
PHP	24
Scala	11
Dockerfile	5
Bash	6
JSON	4
HCL/Terraform	4
Clojure	3
C	2
Swift	2
HTML	1
OCaml	1

No se lista fila por fila (553 reglas, inviable a mano); el fichero completo con id/fichero/lenguaje de cada una esta en [bulk_approved.json](#) (scratchpad de esta sesion). Estas reglas NO han pasado la revision manual de patron/breadth que si se aplico a las 143 reglas anteriores (trailofbits + propias) -- son aprobadas por el criterio automatico exclusivamente.